

ACTIVITÉ 5 – Analyse des vulnérabilités avancées

(OWASP + CWE)

Objectifs pédagogiques

À la fin de cette activité, le stagiaire doit être capable de :

- Analyser une application avec plusieurs vulnérabilités
- Identifier de **nouvelles attaques (non vues dans activité 1)**
- Relier scénario ↔ OWASP ↔ CWE
- Justifier ses choix
- Prioriser les risques

CONSIGNE GÉNÉRALE

- Répondre avec des phrases simples
- Justifier chaque réponse
- Utiliser uniquement le tableau CWE suivant

TABLEAU DES CWE AUTORISÉS

CWE	Quand l'utiliser
CWE-79	Script injecté (XSS)
CWE-284	Accès non autorisé
CWE-287	Authentification
CWE-522	Mot de passe mal stocké
CWE-311	Données non chiffrées
CWE-319	Données en clair (HTTP)
CWE-798	Mot de passe par défaut
CWE-1104	Composant obsolète
CWE-16	Mauvaise configuration
CWE-918	SSRF (requête interne)

PARTIE 1 — Analyse globale (10 points)

Scénario

Une application web présente les problèmes suivants :

- Une API accepte des entrées sans validation (mauvaise conception)
- Le système utilise un mot de passe par défaut

- Une bibliothèque n'est plus mise à jour
- Aucune journalisation n'est activée
- L'application peut faire des requêtes vers des ressources internes (SSRF)

Travail demandé

Compléter le tableau :

Problème	Catégorie OWASP	CWE	Justification	Solution

PARTIE 2 — Identification ciblée (5 points)

Associer chaque cas :

Cas 1 : Une API mal conçue ne filtre pas les entrées.

Cas 2 : Un équipement utilise encore admin/admin.

Cas 3 : Une application utilise une librairie vulnérable.

Cas 4 : Une attaque reste invisible car aucun log n'est enregistré.

Cas 5 : Une application accède à une ressource interne via une URL manipulée.

Réponse attendue

Cas	OWASP	CWE

PARTIE 3 — Priorisation des risques (3 points)

Consigne

Classer ces vulnérabilités du plus critique au moins critique :

- SSRF
- Mauvaise conception
- Mot de passe par défaut
- Composant obsolète

Justifier brièvement

PARTIE 4 — Comparaison avec activité 1 (2 points)

Question

Quelle différence entre :

- Injection (activité 1)
- Insecure Design (activité 2)